

Integración de Autenticación con Azure Entra ID mediante OpenID Connect (Authorization Code Flow)

Tabla de Contenido

1. Resumen General	3
2. Arquitectura de Alto Nivel	3
3. Descripción Técnica del Flujo	4
3.1 Inicio de autenticación	4
3.2 Autenticación en Entra ID	4
3.4 Intercambio de Authorization Code por Tokens	5
3.5 Validación del ID Token	5
3.6 Creación de Sesión Propia	6

1. Resumen General

Objetivo

Describir el mecanismo de autenticación federada implementado entre el sistema OBT de XYZ y Azure Entra ID de Banco XXX.

Alcance

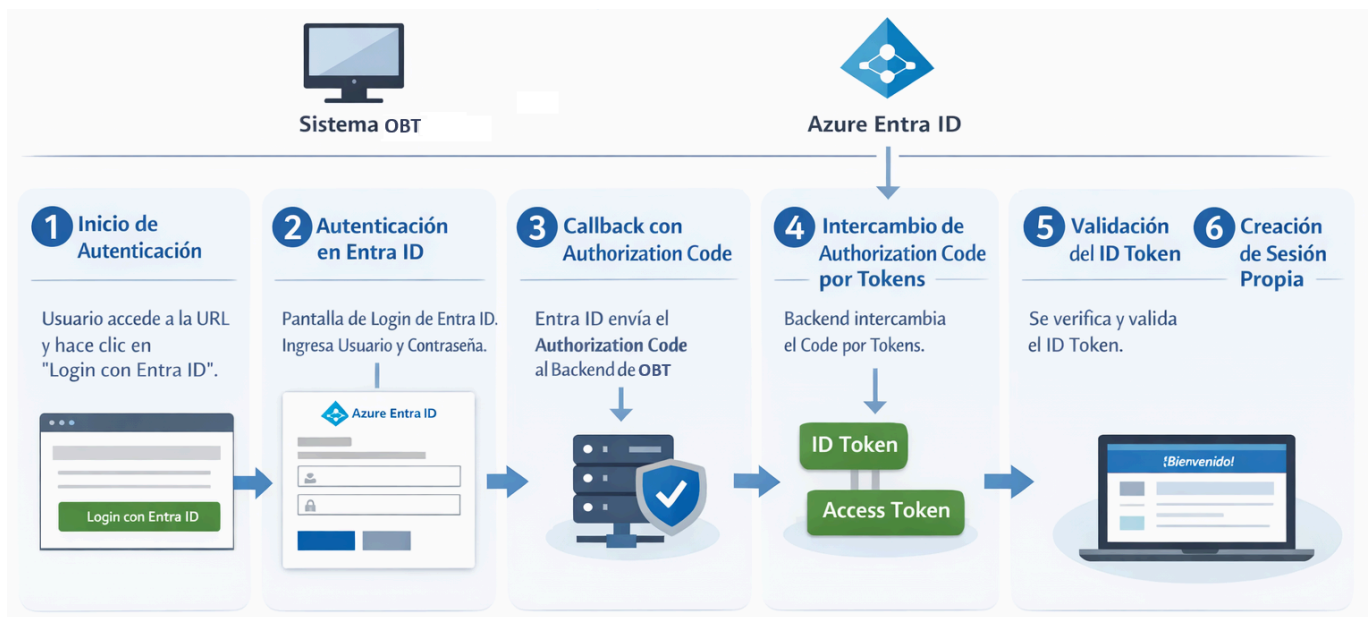
- Flujo de autenticación
- Validación de tokens
- Gestión de sesión
- Controles de seguridad

Tecnologías

- OAuth 2.0
- OpenID Connect
- Authorization Code Flow
- JWT
- HTTPS (TLS 1.2+)

2. Arquitectura de Alto Nivel

Componente	Rol de Seguridad
Usuario	Sujeto autenticado
Frontend UI	Cliente OIDC
Backend	Credential Client
Azure EntraID	Identity Provider (IdP)



3. Descripción Técnica del Flujo

3.1 Inicio de autenticación

Redirección al endpoint:

<https://login.microsoftonline.com/{tenantId}/oauth2/v2.0/authorize>

Parámetros enviados:

```
client_id
response_type=code
redirect_uri
response_mode=query
scope=openid profile email
state
code_challenge
code_challenge_method=S256
prompt=login
```

3.2 Autenticación en Entra ID

Autenticación gestionada por Entra ID.

Se aplican políticas definidas por el área de Gestión de identidades del Banco.

3.3 Callback con Authorization Code

Entra ID redirige al Backend de OBT:

Entorno de Test:

<https://dominio.com/ObtWebServiceDesa/obt/auth/azure/callback>

Entorno de Producción:

<https://obt.dominio.com/ObtWebService/obt/auth/azure/callback>

3.4 Intercambio de Authorization Code por Tokens

Backend OBT realiza:

POST <https://login.microsoftonline.com/{tenantId}/oauth2/v2.0/token>

Parámetros enviados:

client_id
scope=openid profile email
grant_type=authorization_code
code
redirect_uri
client_secret
code_verifier

Respuesta:

ID Token
Access Token

3.5 Validación del ID Token

El backend OBT valida el Token de identidad de EntraID:

Validación	Motivo
Firma Digital	Integridad
iss	Verificar emisor
aud	Verificar destinatario
exp	No expirado
tid	Tenant autorizado
email	Email del usuario autorizado

3.6 Creación de Sesión Propia

El backend redirecciona al Frontend con Tokens propios de OBT:

- Genera JWT interno
- Controla políticas parametrizadas del cliente y permisos del usuario.